

Jornada
Anexo de Segurança, Auditoria e Controle de Acesso

Documento auxiliar à Especificação Técnica v3.60
Versão 1.34 • agosto de 2026

Objetivo. Consolidar o compartilhamento municipal por padrão da Pessoa, as exceções negativas versionadas de projeção, o rate limiting e a trilha de auditoria. A Fase 1 não usa finalidade declarada como mecanismo técnico de autorização. A Jornada autentica/autoriza a credencial de integração, mas não controla nem autentica os agentes humanos dos sistemas finalísticos. Este anexo não substitui a definição institucional de base legal, finalidade, necessidade ou sigilo aplicável ao tratamento de dados.

1. Regra de decisão

Cada consulta funcional exige credencial válida e scope aplicável; credenciais de Tipo permanecem limitadas ao próprio recurso/schema. A existência da Pessoa e o conjunto municipal compartilhado de identificação não dependem de vínculo prévio para GESTOR, BENEFICIO ou SERVICO. Depois dessa etapa, atributos transversais, Registros e Possibilidades podem ser reduzidos por restrições ATIVAS versionadas do Gestor responsável pela informação. Não existe X-Jornada-Finalidade na fronteira da Fase 1.

Contexto	Regra de acesso	Resultado	Resultado
GESTOR	Credencial válida + scope + schema + restrições aplicáveis; sem vínculo prévio	Pode localizar Pessoa e abrir a projeção municipal autorizada.	Pode localizar Pessoa e abrir a projeção municipal autorizada.
BENEFICIO/SERVICO	Credencial válida + próprio recurso + scope + schema; sem vínculo prévio	Pode localizar/consultar a população municipal mantendo a fronteira do código de Tipo.	Pode localizar/consultar a população municipal quando autorizado, mantendo a fronteira do código de Tipo.
Consulta em lote	Cardinalidade do endpoint; autorização atômica; rate limit por CredentialId/classe de rota	Não revela qual UUID falhou em autorização/projeção.	Mesma população municipal, com controles operacionais reforçados.
qualquer	Restrição negativa ATIVA por Gestor consumidor e alvo	Reduz somente a projeção; não apaga a existência da Pessoa nem concede permissão.	400 para código inexistente/inativo ou 403 para credencial sem autorização; nenhuma leitura funcional.
qualquer	Sem restrição ATIVA aplicável	Prevalece a projeção municipal padrão autorizada por scope/schema.	Sem regra ATIVA aplicável, prevalece a projeção municipal padrão.

2. Não enumeração

Falha de autorização/projeção em consulta individual deve evitar enumeração indevida, mas não existe mais uma fronteira populacional por Tipo. A resolução por CPF pode aceitar qualquer tipo de credencial a que seja concedido jornada.identidade.resolve e não oculta uma identidade existente por falta de observação/fato prévio. O CPF do munícipe não é persistido em logs ou auditoria HTTP.

3. Auditoria individual e em lote

controle.api_evento mantém a trilha da requisição. Para alvo único, pessoa_uuid fica na própria linha; para consultas em lote, controle.api_evento_pessoa mantém todos os UUIDs associados ao mesmo api_evento_id/correlation_id. Não são registrados corpo HTTP, access key, CPF do munícipe ou CPF do agente em claro.

Identificação opcional do agente. O sistema finalístico pode enviar X-Jornada-Agente-CPF sob responsabilidade do próprio Gestor. A Jornada não exige gov.br, AD ou qualquer mecanismo de autenticação do agente e não verifica a associação usuário-CPF. Quando o header é informado, a API valida o CPF, remove o header antes de seguir o pipeline, calcula HMAC-SHA-256 determinístico com chave secreta/versionada da instalação e persiste apenas agente_cpf_hash BINARY(32) e agente_hash_versao. Processos automáticos podem omitir o header.

Metadados mínimos: credencial, Gestor, correlation id, rota template, método, status HTTP, duração, recurso lógico, UUID(s) alvo, instante e, quando declarado pela finalística, HMAC versionado do CPF do agente. Índices por Pessoa/agente pseudonimizado permitem investigação temporal sob acesso restrito. O BI não publica esses identificadores individuais.

4. Proteção contra enumeração e abuso

Cardinalidade é propriedade do endpoint. POST /api/v1/pessoas/consulta aceita a faixa definida em contrato (1 a 1000 UUIDs), e a aplicação autoriza o conjunto atômicamente. Rate limits pós-autenticação são particionados por CredentialId e classe de endpoint; não dependem de motivo declarado pelo consumidor. Não existe tratamento especial PRIMEIRO_ATENDIMENTO.

5. HML e Produção

A v3.48 continua deny-by-default fora de Development enquanto a identidade corporativa da credencial de integração não estiver conectada. O processo pode subir e expor health, mas nenhuma credencial funcional é aceita. A entrada em HML exige IdP/secret store corporativo para as credenciais da Jornada, homologação de scopes/recursos, exceções negativas reais de projeção e instrumentos de compartilhamento. Isso não autoriza a Jornada a definir como cada sistema finalístico autentica seus agentes.

6. Testes de referência

A suíte de referência testa ausência de vínculo prévio para GESTOR e credenciais de Tipo, fronteira por recurso de BENEFICIO/SERVICO, HMAC opcional do CPF do agente, QC, rate limiting por classe de endpoint, pipeline HTTP fail-closed e contratos de ingestão. O workflow de CI deve executar unitários e, em job separado com SQL Server, testes Integration contra DDL/seed reais.

7. Rate limiting e alerta volumétrico

O rate limiting opera em duas camadas. A borda aplica limite bruto por RemoteIpAddress normalizado, com margem maior e sem usar X-Jornada-Gestor/Benefício/Serviço como partição antes da autenticação. Depois de resolver a credencial, a aplicação usa CredentialId + classe de rota para os limites institucionais (referência da distribuição: INGESTAO 20/min, IDENTIDADE 30/min, PESSOA 120/min e STANDARD 120/min). Forwarded Headers só é aceito de proxies explicitamente confiáveis. Os valores finais devem ser calibrados em HML.

A observabilidade volumétrica deve usar metadados objetivos de controle por Gestor, credencial, rota e janela temporal. Alertas corporativos podem ser definidos sobre comportamento anômalo sem depender de rótulo de finalidade informado pelo consumidor. UUID/CPF/access key não devem aparecer em logs operacionais.

Não existe consulta SQL de vínculo populacional por Pessoa para BENEFICIO/SERVICO. A fronteira técnica dessas credenciais é o recurso autorizado, seus scopes e schema. HML deve validar o plano das consultas de projeção/restrrição e a cardinalidade dos endpoints, não AllHaveRelationshipAsync nem catálogo de finalidade.

Proteção especial e sigilo usam mecanismo técnico explícito de exceção:

controle.restricao_projecao_jornada_versao. A tabela não inventa a política material; cada restrição precisa ser declarada pelo Gestor finalístico responsável, com versão, vigência, fundamento legal, justificativa e ato_referencia do processo/ato institucional. Sem restrição ATIVA aplicável, prevalece a projeção municipal padrão.

8. Restrições de projeção. controle.fn_projecao_jornada_permitida aplica exceções a ATRIBUTO_PESSOA, REGISTRO e POSSIBILIDADE, considerando Gestor responsável, Gestor consumidor e alvo. Uma restrição só pode ser ativada com alvo válido, reduzindo o risco de regra negativa silenciosamente inoperante por erro de código. Restrições só reduzem a projeção já autorizada por schema/scope; nunca concedem acesso. O conteúdo material de uma versão é imutável e ausência de regra ATIVA significa projeção municipal padrão.

9. Obrigação do sistema consumidor para alertas sensíveis

Fase 2 — alertas sensíveis. Se uma futura tipologia de óbito for implementada, a interface finalística deverá preservar a redação institucional definida na Especificação Técnica, a proibição de efeitos automáticos e a regra de minimização. Essas obrigações deverão constar do termo de adesão/credenciamento e do instrumento de compartilhamento aplicável. A Fase 1 não gera tipologia de óbito nem envia esse alerta.

Auditoria de origem. codigoSistemaOrigem e as chaves locais integram a proveniência do dado e não substituem autenticação/autorização. A autenticação do agente humano e a veracidade do CPF eventualmente enviado em X-Jornada-Agente-CPF pertencem ao Gestor finalístico. A Jornada audita sua própria fronteira por credencial/Gestor/correlation_id e pode conservar somente o HMAC do CPF declarado para correlação. Chaves de acesso continuam fora de payloads e logs.

10. CPF na Fase 1

A Fase 1 não adota criptografia aplicacional por coluna nem tokenização do CPF do munícipe nas tabelas operacionais restritas que necessitam dele para resolução determinística e qualidade. Esse CPF não é dimensão/coluna do Power BI nem integra logs HTTP. O CPF do agente tem tratamento diferente: se a finalística optar por informá-lo, ele nunca é persistido em claro; somente HMAC-SHA-256 versionado é gravado em controle.api_evento. O segredo HMAC fica fora do código/banco e deve ser fornecido por secret store em HML/Produção.

11. Ingestão e proteção de recursos

Na ingestão, autenticação e scope genérico precedem a recepção; o ZIP é escrito em armazenamento temporário local com hash incremental apenas durante a validação inicial. A API lê somente o manifest.json para descobrir o recurso e executar autorização específica antes de descompactar/validar o conteúdo completo. Depois de validar o hash/nome, grava idempotentemente o objeto Bronze definitivo na raiz configurada e somente então persiste a referência no SQL. A objeto_chave é identificador técnico, não credencial nem URL pública. Em HML/Produção, a raiz deve ser compartilhada/durável e protegida por identidade técnica de mínimo privilégio; logs/auditoria não devem registrar caminho absoluto, bytes do payload ou segredo de acesso. O Processor recebe somente a chave relativa e lê o objeto pelas mesmas políticas de storage.

12. Segurança do armazenamento Bronze

O armazenamento Bronze não deve ser publicado diretamente na Internet. A API necessita criar/ler e o Processor somente ler objetos no prefixo autorizado. Em v3.37, apenas Jornada.Bronze.Maintenance.Worker recebe permissão de delete físico. A identidade usada no storage deve ser distinta do segredo funcional dos Gestores e seguir mínimo privilégio; objeto_chave/SHA-256 não é token de autorização.

Integridade e disponibilidade. Objeto canônico existente é re-hasheado; divergência é incidente de infraestrutura. A API devolve 503 + Retry-After para indisponibilidade/corrupção da Bronze, sem atribuir erro ao Gestor. O Processor coloca objeto ausente/divergente em QUARENTENA e reagenda falhas temporárias de I/O.

Expurgo seguro. API e Maintenance Worker coordenam cada SHA-256 por application lock Shared/Exclusive. O mantenedor confirma ausência de referências SQL antes do delete e aplica carência mínima para órfãos/temporários. Rotinas futuras de retenção devem reutilizar esse protocolo; não é permitido delete direto por API/Processor.

Backup/restore. Toda objeto_chave referenciada por qualquer backup SQL ainda restaurável deve permanecer recuperável no storage. A infraestrutura deve alinhar retenção de banco/storage e testar restauração referencial; objetos extras são aceitáveis, referências sem objeto são falha de recuperação.

Atualização v1.14 - staging e territorialização

O staging da API é efêmero e configurável por IngestionStaging:RootPath; não é Bronze, não deve ser exposto publicamente e deve ter ACL/capacidade adequadas. Cleanup por idade é fallback, não retenção de evidência.

A territorialização da Fase 1 é declarada pelo Gestor. A Jornada não envia PII/endereço a serviço geográfico online durante a ingestão, reduzindo dependência externa e superfície de exposição.

Permissões de delete da Bronze continuam restritas ao processo de manutenção; API e Processor não necessitam delete físico do objeto canônico.

A eventual habilitação da retenção de item_processado depende de política institucional aprovada e não altera Silver/Gold.

Hardening v1.14 / v3.39

Cache de contratos não altera autorização: uma nova versão vN só é utilizada quando descoberta pelo catálogo e pelo contexto autorizado. Versões já utilizadas são imutáveis no processo.

Buffers da Bronze devolvidos ao ArrayPool são limpos para reduzir persistência residual de bytes de ZIP com dados pessoais dentro do processo.

Auditoria continua persistida antes do término lógico do middleware; não foi introduzida fila volátil em memória. AuditPersistenceMs é somente telemetria de HML.

13. Integridade global do CPF e correção de identidade

CPF em estado EM_CONFLITO é uma condição de segurança/integridade do identificador: a associação anterior deixa de responder em CPF → UUID e nenhum novo vínculo determinístico é aceito até correção governada. O detalhe do conflito e a aplicação da correção são restritos a credencial GESTOR com scopes jornada.identidade.conflitos.read e jornada.identidade.corrigir. A Jornada não decide qual núcleo é o titular; recebe decisão institucional explícita, ato e justificativa e preserva a trilha append-only.

14. Integridade criptográfica dos contratos

Versões ATIVAS de contrato armazenam SHA-256 aprovado. API e Processor recalculam o digest dos bytes físicos e falham fechado quando ele diverge do catálogo, inclusive após restart. Isso impede que um deploy substitua silenciosamente pessoa.schema.json/registro.schema.json mantendo o mesmo número de versão. O rito de aprovação/ativação do digest continua responsabilidade de governança.

15. BI minimizado

As views de detalhe destinadas ao modelo semântico padrão não expõem `peessoa_uuid`. Contagens distintas de Pessoas são publicadas por views agregadas específicas. O PBIP padrão não deve receber CPF, HMAC do agente ou outros identificadores individuais; workflows de apuração/correção de identidade usam API restrita, não dashboards gerenciais.

16. Integridade factual e retorno de divergências v3.45

Divergência de identidade não autoriza a Jornada a apagar ou ocultar do agregado um fato validamente declarado. O controle de segurança incide sobre a atribuição e sobre a projeção individual: fatos sem atribuição inequívoca não aparecem na Jornada individual.

- `cpf_declarado` permanece em Gold restrita e não integra o Power BI padrão, logs HTTP ou painéis gerenciais.
- `codigo_pessoa_origem` é opaco; a Jornada não valida nem interpreta seu formato como CPF.
- A fila `qualidade.divergencia_gestor` não expõe o conteúdo factual nem CPF/UUID na API de listagem.
- A finalística registra o desfecho; a Jornada não autentica o agente humano nem substitui o controle interno do Gestor.

17. Fechamento de segurança operacional v3.48

- Forwarded Headers só é habilitado com configuração explícita. KnownProxies aceita endereços IP e KnownNetworks aceita redes CIDR IPv4/IPv6; qualquer valor inválido falha fechado no startup.
- A retenção Bronze usa lock exclusivo por SHA compartilhado com escrita e GC, evitando corrida entre deduplicação, leitura operacional e expurgo.
- O verificador pós-restore não confia apenas na existência do arquivo: valida tamanho e SHA-256 para cada referência ainda DISPONIVEL.
- A política de retenção continua desabilitada por default até a governança aprovar RetentionDays; mecanismo técnico e telemetria já estão implementados.

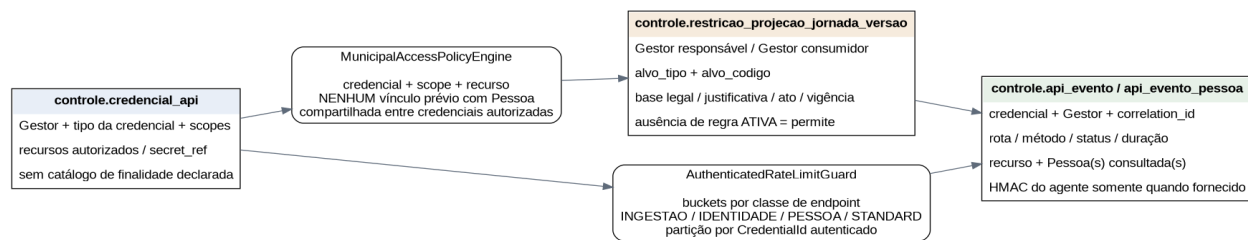
18. Fechamento de segurança operacional v3.49

A v3.49 não modifica a fronteira de acesso. A distinção entre replay técnico e reavaliação normativa preserva auditabilidade: nenhuma mudança posterior de catálogo altera silenciosamente o resultado histórico de uma Entrega.

19. Atualização v1.25 / v3.50

A nomenclatura de acesso passa a usar “Pessoa”/“Pessoa compartilhada em âmbito municipal”, sem criação de entidade organizacional específica. A regra de autorização não muda.

O Programa Reencontro coordena o projeto, mas esse papel institucional não concede acesso, scope, credencial ou capacidade operacional na Jornada. Autorizações continuam derivadas exclusivamente das credenciais técnicas e das regras vigentes.



Atualização v1.25 / Solution v3.51

A terminologia de controle de acesso usa Pessoa como objeto compartilhado entre credenciais autorizadas em âmbito municipal. Programa Reencontro é somente coordenação do projeto e não recebe credencial, scope ou prerrogativa operacional.

Atualização v1.26 / Solution v3.52

O Serviço de Divergências da Fase 1 é somente fila de DIVERGENCIA_IDENTIDADE e registro de desfecho. Comparação cadastral assistida, tipologia óbito e notificações externas permanecem Fase 2. A consulta da Pessoa passa a expor metadados de corroboração no envelope, sem alterar o schema cadastral nem criar nova permissão.

Atualização v1.27 / Solution v3.53

O watchdog operacional é deliberadamente somente observacional e não possui permissão lógica para liberar application locks, encerrar sessões, corrigir estados ou disparar jobs. Alertas estruturados devem ser encaminhados ao stack corporativo de logs/monitoramento sem incluir CPF, payload ou segredo.

O scheduler é infraestrutura corporativa externa à Solution. Cada job deve usar identidade técnica/secret store apropriados e registrar evidência operacional sem introduzir credencial real no repositório.

Atualização v1.28 / Solution v3.54

O ambiente Docker local usa SQL Server Developer e massa sintética. `.env`, credenciais SQL locais, localSettings do Power BI e qualquer segredo de HML/Produção são excluídos do Git. `.env.example` não contém segredo institucional.

Git é a trilha de alteração dos fontes; release exige commit/tag identificável e árvore rastreada limpa. RELEASE_INFO.txt registra a origem do pacote sem armazenar credenciais. O container Developer é explicitamente proibido como configuração de Produção.

Atualização v1.30 / Solution v3.55

Os harnesses v3.55 usam exclusivamente massa sintética e credenciais locais de Development. Fault injection com KILL é permitido somente em banco cujo nome indique Test/Dev e não constitui mecanismo operacional de Produção.

Backups, relatórios de performance e resultados TRX locais ficam sob Solution/.local e são excluídos do Git. Nenhum segredo de HML/Produção, backup real ou dado pessoal deve ser usado nos ensaios locais.

Atualização v1.31 — sigilo localizado no dado, não na Pessoa

Não existe marcador geral PROTECAO_ESPECIAL na Pessoa. A proteção da casa-abrigo é localizada no atributo ENDERECO_CASA_ABRIGO_SIGILOSA.

Somente o próprio Tipo de Serviço de casa-abrigo explicitamente habilitado pode originar o atributo. A plataforma não deduz sigilo pelo Gestor, pela existência de acolhimento ou pelo local de atendimento.

O endereço sigiloso não é projetado para outro Gestor. O bloqueio é estrutural e precede as exceções negativas configuráveis. Os demais dados da Pessoa mantêm o compartilhamento municipal autorizado.

Atualização v1.32 / normativa v3.58

Não enumeração de atributos suprimidos: a ausência de um atributo na resposta não permite concluir que ele inexistente na origem ou na Gold. A borda não devolve marcador RESTRITO/PROTEGIDO para campos retirados pelo schema ou pela regra de projeção, evitando revelar a própria existência de dado sensível.

Continuidade de UUID após FUSAO_HISTORICA: auditoria registra UUID solicitado e canônico quando houver redirecionamento; a Pessoa absorvida permanece FUNDIDO com sucessor explícito. A migração de identificadores gera eventos de estado, e CPF ativo divergente impede fusão automática.

Atualização v1.33 / normativa v3.59

A v3.59 não amplia a fronteira de acesso. O erro 51119 é proteção de integridade da operação governada de identidade e TELEFONE_BR_CANONICO_V2 é normalização de chave de instância; regras de autorização, projeção, não enumeração e sigilo de casa-abrigo-sigilosa permanecem inalteradas.

Atualização v1.34 / normativa v3.60

A v3.60 não amplia acesso nem superfície de dados. As validações 51117/51118/51119 são controles de integridade do ato governado e ocorrem antes das mutações da aplicação, reduzindo risco de estado parcial em execução administrativa direta.

A reconciliação TELEFONE_BR_CANONICO_V2 usa o valor original apenas para derivar a chave lógica de contato durante o upgrade. Valor legado incompatível interrompe o upgrade; a mudança não relaxa autorização, projeção, não enumeração ou sigilo.